

(주)온다로지스 수탁사 점검 결과 보고서

수탁사 (피감사)	(주)온다로지스
위탁사 (감사 주체)	(주)하랑항공
위탁 업무 범위	항공화물 운송·배송 물류 위탁 운영 일체
점검 기간	2026년 01월 26일 ~ 2026년 02월 13일
보고서 작성일	2026년 02월 23일

본 보고서는 (주)하랑항공이 위탁한 물류 운송 업무 수행과 관련하여
(주)온다로지스의 개인정보 보호 관리 수준을 점검한 결과를 기술한 문서입니다.

개정 이력

버전	변경일	변경 사유	변경 내용	작성자	비고
1.0	2026-02-16	최초 작성	결과 보고서 초안 작성	(주)리베로	
1.1	2026-02-18	내용 수정	2.1 진단 결과 변경	(주)리베로	
1.2	2026-02-25	내용 수정	증적 자료 추가	(주)리베로	
1.3	2026-03-03	내용 수정	증적 자료 수정	(주)리베로	
1.4	2026-03-13	내용 수정	향후 조치 일정 수정	(주)리베로	

목차

1. 진단 결과 요약	4
1.1 보안 준수율 분류 기준	4
1.2 종합 등급	4
1.3 범주별 등급	5
1.4 핵심 위험 사항 (즉시 조치 필요)	6
2. 범주별 상세 점검 현황	7
2.1 내부 관리 계획 및 조직	7
2.2 접근 통제 및 권한 관리	8
2.3 접속기록 보관 및 점검	8
2.4 비밀번호 관리	8
2.5 접속 보안 및 네트워크	8
2.6 단말기 보안	8
2.7 개인정보 암호화 및 출력 통제	8
2.8 개인정보 생명주기	9
3. 증적자료 목록 및 첨부	10
4. 결론 및 향후 조치 계획	16

1. 진단 결과 요약

1.1 보안 준수율 분류 기준

분류	양호(Y)	부분양호(P)	취약(N)
점수	1	0.7	0

총점	100 ~ 90	89 ~ 70	69 ~ 50	49 ~ 0
등급	A	B	C	D

- 각 점검항목을 양호, 부분양호, 취약으로 평가하여 분류한다.
- 총점은 53개의 점검항목 점수의 합산을 100점 만점으로 환산한 값이다.
환산 점수 = $\frac{(\text{양호 개수}) \times 1 + (\text{부분양호 개수}) \times 0.7 + (\text{취약 개수}) \times 0}{\text{점검 항목 수}} \times 100$
- 환산 점수에 따라 90점 이상은 A, 70점 이상 90점 미만은 B, 50점 이상 70점 미만은 C, 50점 미만은 D로 등급을 산정한다.

1.2 종합 등급

종합 등급	양호	부분양호	취약
D	13건	18건	22건

- 점검결과 취약 22건, 부분양호 18건을 포함하여 총 40건에 대한 개선 조치가 필요하다.

1.3 범주별 등급

점검 영역	등급	주요 취약 사항
내부 관리 계획 및 조직	C	핵심 통제 항목 누락, 정기교육 전무
접근 통제 및 권한 관리	D	공용 계정 사용, 최소 권한 원칙 위반, 추가인증 전무
접속기록 보관 및 점검	D	로그 필수항목 누락, 보관 기한 위반, 탐지 룰셋 전무
비밀번호 관리	D	비밀번호 생성 단계에 복잡도 필터링 적용, 비밀번호 재사용 금지 로직 누락, 단말 자동 잠금 기능 활성화
접속 보안 및 네트워크	C	망분리 붕괴, 클라우드·메일 유출 경로 개방
단말기 보안	B	PC 기본 공유 개방, 비인가 SW 설치 방치
개인정보 암호화 및 출력 통제	D	파일 암호화 미적용, 키 관리 전무, 평문 전송, 출력물 관리대장 전무
개인정보 생명주기	D	전자·종이 파기 통제 전무, 백업 파기 연동 미비

1.4 핵심 위험 사항 (즉시 조치 필요)

- 인도장 내 화물 지시서 무단 방치 및 문서고 열쇠 정보 공유로 인하여 비인가자의 물리적 접근 및 고객 정보 노출 위험이 존재
- 연 1회 법정 개인정보보호 교육 전면 미수행 및 증적 부재로 인하여 전 직원의 보안 인식이 결여되었으며 개인정보 보호법 위반에 따른 과태료 부과 위험
- 실사용자가 불분명한 보조 조회용 그룹 계정 다수 발급으로 인하여 개인별 식별이 불가능하며 부정 접근 발생 시 책임 추적 및 사후 대응이 불가능
- 현장 검수원 대상 불필요한 화물 수정 및 배차 취소 권한 부여로 인하여 권한 오남용에 따른 데이터 임의 변조 및 업무 절차 왜곡 리스크가 심화
- 권한 변경 전산 로그 보존 기한(1년) 법정 기준 미달 설정으로 인하여 법정 기준인 3년 미준수는 물론 보안 사고 발생 시 장기 이력 추적이 불가능
- 공용 PDA 단일 계정 무단 공유 및 추가 인증 수단 부재로 인하여 사용자 간 계정 도용 위험이 크고 사고 행위자 특정 불가로 인한 보안 책임 공백이 발생
- 레거시 스캐닝 프로그램 패스워드 무차별 대입 방어 기능 전무로 인하여 브루트포스 공격을 통한 내부 시스템 침입 및 대규모 정보 유출 위협에 노출
- 비밀번호 90일 정기 변경 누락 및 1년 이상 동일 암호 방치로 인하여 단순 패턴 및 장기 미변경 암호 사용에 따른 계정 탈취 위험이 가중
- 가상화(VDI) 우회 양망 접속 및 클립보드 복사 방치로 인하여 망분리 환경이 무력화되었으며 업무망 내 개인정보의 외부 무단 반출 경로가 개방
- 클라우드·개인 이메일 예외 허용 및 비인가 캡처 프로그램 사용으로 인하여 비인가 경로를 통한 우회적 정보 유출 및 보안 통제 사각지대가 발생
- NAS 내 출고 리스트 폴더 익명 개방 및 엑셀 암호 미설정으로 인하여 사내 임직원 누구나 제약 없이 대량의 고객 명단을 취득하고 복사 위험
- 업무 단말기 로컬 드라이브 내 고객 명단 엑셀 파일 평문 저장으로 인하여 단말기 분실, 도난 또는 악성코드 감염 시 개인정보 유출 사고 가능성
- 이메일 및 메신저(카카오톡)를 통한 배송 명단 평문 전송 관행으로 인하여 전송 구간 암호화 미적용 및 파일 암호 부재에 따른 제3자 정보 유출에 직접 노출
- 화면 캡처 차단 솔루션 부재로 인한 우회적 정보 수집 방치로 인하여 계약 목적 외 원장 정보의 무분별한 캡처·기록 및 가공 행위 통제가 불가능
- 물류 현장 내 하랑항공 지시서와 일반 화물 출력물 혼재 방치로 인하여 수탁 정보와 일반 정보의 물리적 분리 관리 미흡에 따른 오용 가능성이 상존
- 본사 승인 없는 현장소장 임의 영세업체 무단 재위탁 구두 지시로 인하여 재수탁사 보안 관리 감독 체계 이탈 및 위탁 계약 위반 리스크가 발생
- 제3자 제공 기록 관리대장 작성 전면 누락으로 인하여 외부 택배사 등 정보 이관 시 법정 필수 증적이 부재하여 규제 기관 적발 위험 존재
- 지시서 무단 쓰레기통 투기 및 파기 관리대장 작성 전무로 인하여 물리적 파쇄 절차가 무시되고 있으며 파기 의무 이행에 대한 객관적 증빙이 불가능

2. 범주별 상세 점검 현황

2.1 내부관리 계획 및 조직

- 내부관리계획서의 필수 항목과 승인 절차는 갖추고 있으나, **개정 법령(72시간 통지 등) 미반영, 세부 실행 절차(위험분석·수탁자 감독) 누락 및 파견 인력의 역할 구분 미비**
- 내부관리계획서가 그룹웨어 내 상시 게시되어 있고, 제·개정 이력 및 임직원 열람 로그 등 공표 체계 전반이 규정에 따라 투명하고 적절하게 관리
- 대응절차서와 보고 양식은 갖추고 있으나, 담당자들의 보고 의무 인지 부족, 비상연락처 최신화 미비(퇴사자 등) 및 야간·공휴일 연락 체계 누락 등 **실질적인 대응 운영이 미흡**
- 재해 복구 매뉴얼과 복구 목표(RTO/RPO)는 수립되어 있으나, **최근 2년간 복구 모의 훈련 이력이 전무하여 실효성 검증이 불가능하고, 외부 소산 백업 미적용 및 복원 테스트 미실시**
- CISO의 임명 및 자격 요건은 적절히 갖추고 있으나, **부재 시 대리 결재 규정이 미정립되어 보안 결재 지연이 빈번하게 발생하는 등 실무 운영의 실효성이 부족**
- 공향 파견 엔지니어 명단과 취급자 지정 현황이 적절히 관리되고 있으며, 인사 DB 연동을 통해 퇴사자 제명 및 목록 최신화가 자동화 체계로 누락 없이 운영
- 전자결재 시스템을 통한 서약서 제출 이력이 철저히 관리되고 있으며, 입사 및 프로젝트 투입 시 누락 인원 없이 전 임직원의 서약서 징구와 원본 보관 체계가 정상적으로 운영
- **연간 교육 계획과 예산이 전무하며, 고유식별정보를 취급하는 파견 엔지니어를 포함하여 전 취급자가 2년 연속 교육을 미실시하는 등 교육 체계가 전무**
- 지문 인식 및 스마트 직원증을 통한 출입 통제, 보호구역 모니터링, 방문객 관리 및 퇴사자 권한 즉시 삭제 프로세스가 규정에 따라 체계적으로 운영
- 서버실 카드리 출입 통제는 이루어지고 있으나, 유지보수 편의를 이유로 서버 랙 3대 중 2대가 상시 개방되어 있고 **잠금 관리 절차 및 대장이 부재**
- 캐비닛 잠금장치는 구비되어 있으나, 문서 보관 관련 규정이 부재하고 일과 중 상시 개방 관행 및 **이동 시 보안 인장 미부착으로 인해 무단 열람 가능성이 존재**

2.2 접근 통제 및 권한 관리

- 1인 1계정 원칙은 적절하나 **현장 내 목적 불명의 보조 공유 계정 다수 발급**
- 단순 조회 업무를 하는 현장 검수원에게 화물 수정 및 배차 취소 등 **과도한 권한 부여 관행 확인**
- 개인정보처리시스템 계정 및 권한 신청 시 책임자 승인 상태 양호
- 야간 교대 현장 인력 퇴사 시 행정 처리 지연으로 전산 **권한 회수 최대 3일 지연**
- 법정 보관 기준에 미달하는 권한 변경 **로그 법정 보존 기간 미달**
- 현장 공용 단말기에 단일 계정 **비밀번호** 메모 부착 및 다수 인원 **무단 공유**
- 잦은 재접속 불편 사유로 현장 **단말기 대기 시간 60분** 과도 설정 및 기기 방치
- 기존 물류 스캐닝 프로그램 접속 시 **무차별 대입 공격 방어 기능 부재**

2.3 접속기록 보관 및 점검

- 로그 기록 부재 및 정보 주체 식별 등 **법정 핵심 필수 항목 누락**
- 정기 검토 체계 미흡 및 탐지 룰셋, 개별 행위자 추적성 부재
- 정기 백업 체계 부재, 시스템 용량 부족 사유로 로그 보관 주기를 임의로 축소하여 유지
- WORM 스토리지 적용 상태 양호, 해시 생성 및 물리적 격리 백업 아키텍처 구축 상태 양호

2.4 비밀번호 관리

- 복잡도 미설정, 갱신 주기 강제화 및 단순 패턴 유추 방지 장치가 전무
- 자동 잠금 및 패스워드 입력 프롬프트는 양호하나 **현장 화면 잠금 실패 부실**

2.5 접속 보안 및 네트워크

- 외부망 접속 시 안전한 접속 터널링 및 2차 인증을 기술적으로 강제
- 네트워크 접근통제 장비 정책 설계, 룰셋 관리, 모니터링 체계가 모두 정상 작동
- 현장 관리자 단말이 가상화(VDI) 우회 등을 통해 인터넷망과 내부 업무망에 동시 접속 가능
- 클라우드, 메일 등 유출 경로가 **예외 허용**으로 열려있고 **비인가 캡처 툴 등 무단 사용이 방치**
- 업무망 WMS 화면에서 고객 정보를 외부 인터넷으로 복사 가능한 **파일 우회 반출 경로 발견**
- 승인/인증 절차는 양호하나 **WIPS 부재**로 임의 테더링 등 물리적 우회를 방지할 기술적 통제 미비

2.6 단말기 보안

- 연 1회 이상 취약점 점검 및 조치 결과 증빙 부재
- 서버 보안 백신의 전수 설치, 엔진 자동 갱신, 실시간 감시가 중앙에서 일괄 통제
- 정기 보안 패치와 EOS 관리를 정책에 맞춰 이행
- **공유 폴더의 기본 접근 제한 부재 및 파일 암호 미설정으로 내부 유출에 취약**
- PC 엔드포인트 방어 솔루션이 중앙 통제 및 강제화, 네트워크 격리와 연계 상태 양호
- PC 및 응용프로그램 패치 중앙 관리 프로세스가 시스템적 유지 상태 양호
- 보조매체 차단 및 예외 승인 시스템, 물리적 반출 통제 상태 양호

2.7 개인정보 암호화 및 출력 통제

- 관리자 포털의 모든 계정 비밀번호가 **암호화나 솔트(Salt) 처리 없이 평문으로 저장되어 있어, 내부자 열람 및 유출 시 비밀번호가 즉각 노출되는 보안 결함**
- 키오스크 로컬 DB에 여권번호 등 고유식별정보가 암호화 알고리즘 적용 없이 **평문으로 저장되어 있으며, DB 파일 자체에 대한 물리적 복사 및 접근 통제 기능 부재**
- 키오스크와 인터페이스 서버 간 통신에 최신 보안 프로토콜인 TLS 1.3이 적용되어 있고, **하위 버전(TLS 1.0/1.1) 접속이 차단**
- DRM 솔루션이 부재하여 개인정보 포함 문서에 대한 **자동 암호화 강제 기능 부재 및 사후 관리 체계, 대안 정책 미흡**

- 암호화 키 관리를 위한 인증서와 비밀키는 보유하고 있으나, **API 비밀키가 설정 파일에 평문으로 하드코딩**되어 있고 전용 관리 시스템(KMS)이나 안전한 보관 방식 부재
- 운영 모드에서는 마스킹이 정상 적용되어 있으나, **별도의 인증 없이** 단순 키 조합만으로 진입 가능한 디버깅 모드에서 여권번호와 성명이 **평문으로 노출** 및 해당 모드가 활성화된 채 배포
- **출력물 관리 절차와 파기 규정 부재**

2.8 개인정보 생명주기

- 시스템 자동 연동 항목 최소화 원칙 준수되나 예외 보상 시 콜센터 직원 **임의 추가 정보 수집 관행**
- (주)하랑항공 배송 데이터의 DB 논리 격리는 양호하나 현장 실물 문서와 일반 화물의 **식별 분리 관리 미흡**
- 물량 폭주 시 본사 승인 없이 물류 소장 임의로 영세 하역업체 **무단 재위탁 구두 지시**
- 재수탁사 보안 실태에 대한 정기 점검 및 관리 감독 이력 부재, **현장 인력 보안 서약 체계 누락**
- 지역 하청 소장 개인 메일로 개인정보 명단 **무단 이관 적발** 및 **제3자 제공 대장 전무**
- 운영 DB 자동 삭제 로직은 작동하나 백업 스토리지 내 파기 연동 누락으로 **장애 복구 시 개인정보 재생성 위험**
- 목적 완료된 종이 지시서를 파쇄하지 않고 **일반 폐기물 투기** 및 **파기 대장 미작성**
- 최근 1년 반 동안 위탁사 (주)하랑항공 대상 **개인정보 파기 완료 결과보고서 정기 전송 실적 전무**
- 하드카피 서류가 일반 서류와 **혼재 보관**되어 물리적 목적 외 열람 접근 분리 통제 미흡

3. 증적자료 목록 및 첨부

본 진단 결과보고서에 첨부되는 증적자료 목록입니다. 각 자료는 점검 기간(2026.01.26~02.13) 중 수집·확인된 원본 또는 사본입니다.

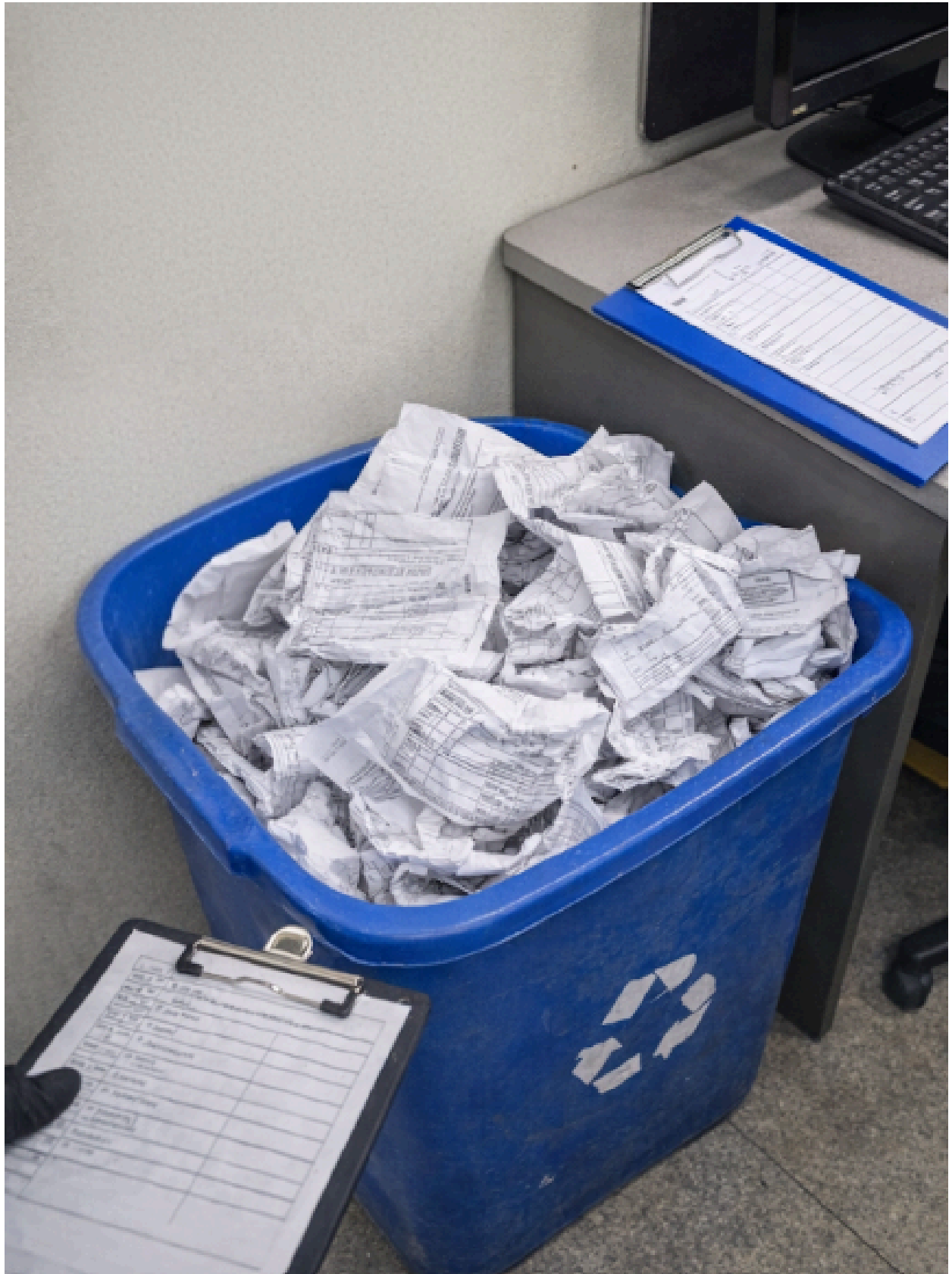
No.	분류	증적자료명	형태	수집일	확인자
1	내부 정보	개인정보 파기 증적 사진	현장사진	2026.01.26	명승혁
2	내부 정보	와이핑 툴 구매 영수증, 라이선스 확인서	문서 사본	2026.01.28	임희은
3	내부 정보	내부관리계획서에 대한 전자 결재 캡처	문서 사본	2026.02.02	임희은
4	접속 기록	로그 보존 설정 화면 사진	화면 캡처본	2026.02.03	명승혁
5	내부 정보	인도장 출입통제 장치 사진, 문서 이동용 보안 싼 캡처	현장 사진	2026.02.05	명승혁

※ 위 목록에 포함되지 않은 추가 증적자료는 별도 협의 후 제출합니다.

※ 각 증적자료 원본은 (주)하랑항공 보안컨설팅팀이 보관하며, 수탁사 요청 시 열람 가능합니다.

[증거자료 실물 첨부 공간]

증적 1



소프트웨어 구매 영수증

(주)데이터세이프 보안솔루션

소프트웨어 구매 영수증

PURCHASE RECEIPT

PUR-2024-0522-01

결제 정보

문서 번호 : PUR-2024-0522-01	상호명 : (주)데이터세이프 보안솔루션
결제 일자 : 2024년 5월 22일	사업자번호 : 123-45-67890
결제 수단 : 법인카드 (BC카드 1234-****-0000)	대표자 : 홍길동

공급자 정보

종명	수량	단가	금액
(1) SecureEraser Pro v5.0 (Enterprise Edition)	10	150,000원	1,500,000원
(2) 연간 유지보수 및 업데이트 서비스	1	300,000원	300,000원

* (주)데이터세이프 보안솔루션

보안솔루션

2024년 5월 22일

사업자 123-45-67890

* 본 구매 영수증은 SecureEraser Pro v5.0 정품 라이선스 취득에 대한 증빙 자료이며,
영수증의 내용은 라이선스 증서와 일치해야 합니다.

(주)데이터세이프

SOFTWARE LICENSE CERTIFICATE

소프트웨어 라이선스 인증서

라이선스 번호 : LIC-SEC-2024-9981

사용자 발급 대상 : ㈜온다로지스

본 증서는 귀하가 SecureEraser Pro v5.0 (기업용 영구 라이선스)를 정당하게 구매하여 사용권을 보유하고 있음을 인증합니다.

제품명	SecureEraser Pro v5.0
버전	v5.0 Enterprise Edition
라이선스 유형	기업용 영구 라이선스 (Perpetual License)
도입 수량	10 Copy (관리 대상 단말기 10대)

주요 기술 규격

- DoD 5220.22-M (미 국방성) 표준 알고리즘 지원
- Gutmann 방식 총 35회 덮어쓰기 지원
- 파기 후 복구 불가능 리포트 자동 생성 기능

발급일 : 2024년 5월 25일

발급처 : (주)데이터세이프 보안솔루션 (인)

2024년 5월 25일

달당 결재 김○○ 2025.12.01	팀장 결재 이○○ 2025.12.02	본부장 결재 박○○ 2025.12.03	대표이사 (미결재) 승인 필요
-------------------------------	-------------------------------	--------------------------------	------------------------

개인정보보호 내부관리계획서 개정 승인의 건

기안부서 : 경영지원본부 정보보안파트 · 기안자 : 김○○ 선임 · 기안일 : 2025.12.01

문서번호	OL-SEC-2025-018	보존기간	영구
기안일	2025년 12월 01일 (월)	문서등급	대외비 (수신자 외 배포 금지)
시행일	2026년 01월 01일 (예정)	참조	경영지원본부장
관련근거	개인정보보호법 제29조(안전조치의무) / 동법 시행령 제30조(개인정보의 안전성 확보 조치) / 개인정보의 안전성 확보조치 기준(개인정보보호위원회 고시)		

1. 개정 배경 및 목적

당사는 ㈜하랑항공으로부터 위탁받은 항공화물 운송·배송 물류 위탁 운영 업무와 관련하여 개인정보보호법 제29조(안전조치의무) 및 동법 시행령 제30조에 따라 내부관리계획서를 수립·운영하고 있습니다.

현행 내부관리계획서(ver 2.1)는 2024년 11월 제정 이후 재위탁 인력 통제·접속기록 보관 기한·파기 절차 등 현장 환경 변화가 반영되지 않은 상태이며, 법령 요건 충족을 위한 전면 개정이 필요합니다.

2. 주요 개정 내용

1	재위탁 인력(지입차주) 통제 조항 신설	→ 현장 단말기(PDA) 물리적 안전조치 항목 추가 및 지입차주 보안 관리 기준 명문화
2	접속기록 보관 기한 조항 강화	→ 모바일 API-PDA 연동 구간 2년 이상 보관 기준 명시 (고유식별정보 취급 사업자 기준 적용)
3	개인정보 파기 절차 세분화	→ 전자파일·DB·종이문서 각 매체별 파기 기준 및 중병 수립, 위탁사(하랑항공) 정기 보고 의무 조항 신설
4	재난·재해 BCP 보완	→ 무선AP 장애·PDA 대량 파손 시 종이 지시서 임시 운영 절차 및 현장 연계 모의훈련 계획 추가
5	제3자 제공 기록 관리 조항 신설	→ 제3자 제공 기록 관리대장 작성 의무 및 사전 승인 결재 절차 규정 신설

3. 개정 문서 현황

문서명	㈜온다로지스 개인정보보호 내부관리계획서
-----	-----------------------

증적 4

System Component	Log Type	Current Retention	Storage Location	Compliance Status	Actions
WMS Core System	Master Ledger Access Logs	2 Years (Default) ▾	Cold Storage Pool A	● Compliant	<button>Edit</button>
Mobile Application (API Gateway)	User Activity Logs	6 Months (Rotation) ▾		● Fast SSD Pool B (95% Full)	<button>Save Changes</button>
		1 Year			
		2 Years (Required)			
PDA Linkage System	Device Sync Logs	6 Months (Rotation) ▾		● Fast SSD Pool B (95% Full)	<button>Save Changes</button>
		1 Year			
		2 Years (Required)			
Database Server	DB Audit Logs	2 Years ▾	Cold Storage Pool A	● Compliant	<button>Edit</button>

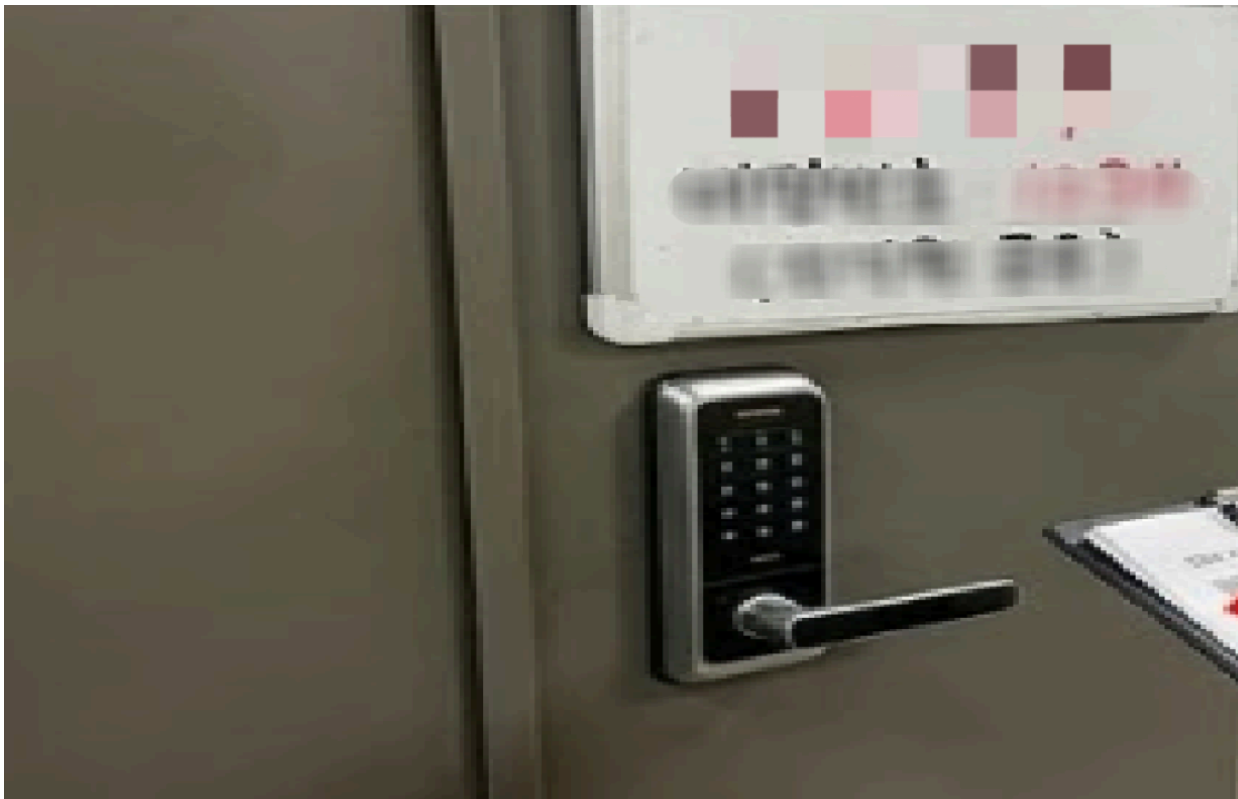
3. System Actions

Fix All Compliance Issues (Apply 2 Year Minimum)Run Full System Scanning >

Notice regarding Storage Capacity:

Increasing retention for Mobile/PDA systems to 2 years requires immediate allocation of additional storage space to prevent data loss or system errors.

증적 5



4. 결론 및 향후 조치 계획

(주)온다로지스는 위탁받은 항공화물 운송·배송 물류 위탁 운영 업무 수행에 있어 CISO 지정, 보안서약서 징구, 서버 백신·패치, 외부 접속 통제(VPN·MFA), 개인정보 마스킹 등 일부 보호 조치가 구축되어 있으나, 개인정보보호법 위반 소지가 있는 중대 취약점이 다수 확인되었습니다.

특히 공용 계정 사용에 따른 책임 추적성 상실, 이메일·메신저를 통한 배송 명단 평문 전송 관행, 무계약 제3자에게의 운송장 무단 이관, 망분리 붕괴를 통한 개인정보 우회 반출 경로 개방, DB 파기 시 백업 스토리지 연동 물리 파기 로직 누락은 실제 침해 사고 발생 시 위탁사인 (주)하랑항공의 법적 책임으로 이어질 수 있어 조속한 개선이 요구됩니다.

향후 조치 일정

구분	일정	내용
조치 계획서 제출	2026년 04월 24일까지	(주)온다로지스 → (주)하랑항공 제출
긴급 항목 조치	2026년 05월 24일까지	고위험군 즉시 차단
단기 항목 조치	2026년 08월 25일까지	보안 설정 및 프로세스 정비
중기 항목 조치	2026년 10월 25일까지	인프라 및 기술적 고도화
재점검	2026년 11월 중	(주)온다로지스 서면 재점검 및 최종 조치 결과 확인

각 자료는 점검 기간(2026.01.26~02.13) 중 수집·확인된 원본 또는 사본입니다.

본 보고서는 대외비이며 수신자 외 무단 배포 및 공개를 금합니다.

작 성	검 토
소속 : (주)리베로 보안컨설팅팀	소속 : (주)하랑항공 개인정보보호팀장
성명 : 최 호 준 (서명)	성명 : 김 희 민 (서명)
일자 : 2026년 03월 13일	일자 : 2026년 03월 13일